PT ASCENDO INTERNASIONAL

ASM 권한 및 승인 설계서

ASM 권한 가이드라인 v3.0을 기준으로 권한 모델(RBAC · C1~C4), 역할별 책임과 제한, 기능 권한 기준, 직무분리(SoD) 금지 조합, 승인 Workflow, Export·감사·비상권한 통제를 개발 기준으로 정리한 문서.

문서명	ASM 권한 및 승인 설계서 (Authorization & Approval Design · Desain Hak Akses dan Persetujuan)
문서번호	DOC-06 · Draft v1.2.3 · 기준일 2026-10-21
개정 이력	v1.0 (2026-09-02 초안) → v1.1 (2026-09-02) — 권한 가이드라인 v3.0 전면 반영 — 역할 정의 15종 · 마스킹 매트릭스 · C1~C4 구현 기준 · 승인 매트릭스 10항목 · 보상통제 · 생애주기 · 물리보안 · 역할×모듈 16종 매트릭스 → v1.2 (2026-09-03) — arc42 대응 표기 → v1.2.1 (2026-09-03) — 시스템 명칭 정정: ASM = Ascendo Sales Management System (ERP 표기 삭제) → v1.2.2 (2026-09-03) — 정합성 검증 v3.3 반영: 적용 범위 승인 Workflow 7종→매트릭스 10항목, 권한 변경 승인선 정정(R0-A 승인권한 배제 → R0-B 1차·R1 최종), R6·R7 결번 표기, 기준일 갱신 → v1.2.3 (2026-10-21) — R1 최종승인권자 김재헌 · 서종환(김재헌 상무 대행) 확정, 거점코드 SMG→SMR, 기준일 갱신
arc42 대응	§8 Cross-cutting Concepts (보안 · 권한 · 승인 · 감사)
대상 시스템	ASM — Ascendo Sales Management System (asm.ascendotyre.com). PT ASCENDO INTERNASIONAL 타이어 수입·유통 판매관리 시스템
적용 범위	역할 R0-A/R0-B/R1~R13(R6·R7 결번)/EA · 통제코드 C1~C4 · SoD 6조합 · 승인 매트릭스 10항목 · Workflow
작성 목적	개발·검토·테스트 기준선(Baseline) 수립 — 개발부서 협의 · 사내 업무 표준
문서 상태	실화면 및 제공자료 기반 초안. 현업/개발부서 합의 후 Baseline 확정
근거 문서	ASM 권한 가이드라인 v3.0 · ASM 업무 프로세스 정의서/맵 (2026-09-01) · ASM 시스템 테스트 결과 및 개선 의견서 (38건) · ASM 문서 정합성 검증 리포트 v3.3 · ASM 디자인 가이드(안) · ERP 웹앱 개발 순서 및 필요 문서

1. 권한 모델 Model Hak Akses

Company → Branch → Department → Role → User → Permission 구조를 사용하며, 개인 직접권한(개별 사용자에게 직접 부여하는 권한)은 원칙적으로 금지. 권한은 메뉴 단위가 아닌 기능 단위(View / Create·Edit / Approve·Confirm / Export)로 관리.

코드	통제
C1 Scope	소속 지점 · 담당 고객 · 담당 창고 행만 조회/편집 (RLS · Row-Level Security)
C2 Masking	원가 · 마진 · 여신 · 미수 등 민감 필드를 *** 또는 제한값으로 표시
C3 Draft	작성 · 수정은 가능하나 확정 불가
C4 Approval	업무 수행은 가능하나 승인 완료 전 확정 불가

1.1 권한수준 기호 정의

기호	의미 (KR / EN)	개발자 정의
●	전체관리 / Full Control	CRUD + 설정 / 승인 — 모듈 전권
◐	생성 · 편집 / Create · Edit	생성 · 수정 — 삭제 · 환경설정 · 승인 제외
○	조회 / View Only	읽기 전용
◍	조건부 / Conditional	C1~C4 조건 충족 시에만 동작
—	권한 없음 / No Access	메뉴 · API 미노출

1.2 조건코드 C1~C4 개발 구현 기준

코드	유형	구현 방식	판정 기준 컬럼	적용 계층	우회 위험
C1	범위 제한 (Scope)	Row Level Security — 쿼리에 소속 · 담당 조건 강제 주입	branch_id · sales_rep_id · customer_owner_id	DB / API 계층	프론트 필터만 적용 시 우회
C2	필드 마스킹 (Masking)	응답 직렬화 단계에서 필드 제거 후 *** 치환	role_code × field_class	서버 응답 생성 단계	CSS · 화면 숨김은 무효
C3	초안 전용 (Draft)	status='DRAFT' 까지만 저장, 확정 API 호출 차단	doc_status	API 상태 전이 검증	상태값 직접 전송 차단 필요
C4	승인 상신 (Approval)	전자결재 상신 → 승인 완료 시에만 확정 처리	approval_status	결재 엔진 (승인 매트릭스 연동)	승인 우회 API 금지

개발 원칙 — 범위 제한(C1) · 필드 마스킹(C2)은 서버 측 처리 필수. 화면 숨김(front-end hide / display:none)은 API 직접 호출 시 원본 값 그대로 반환되므로 보안 통제 불인정, 감사 시 결함 판정. 근거 — ISO/IEC 27001:2022 A.5.12 · A.8.3, 인도네시아 UU No. 27/2022 (PDP) 제35~36조.

2. 역할 정의 Definisi Peran

13역할 + NA + 비상(EA). R0-A 시스템 / R0-B 보안 분리. 권한 부여 대상은 개인이 아닌 역할(Role) 한정, 개인 직접 부여 0건 원칙(예외 시 사유 · 만료일 명시).

역할	역할명 (KR / EN)	대상 · 홀더	데이터 범위	핵심 권한	인원
R0-A	시스템 관리자 / System Admin	IT 이정규 (KR)	전사 + 시스템	계정 · 권한 · 환경설정 · 마스터 구조 (감사로그 제외)	한국 1
R0-B	보안 관리자 / Security Admin	IT 금기돈 (KR)	전사 + 보안	감사로그 관리 · 보안정책 · 권한변경 검토 (계정생성 제외)	한국 1

역할	역할명 (KR / EN)	대상 · 홀더	데이터 범위	핵심 권한	인원
R1	경영진 / Executive	COO 김재헌 · G/M 서종환 (김재헌 상무 대행) (KR)	전사	전 모듈 조회 · 최종 승인 · 마진책정 · 원가열람	한국 2
R2	영업 관리자 / Sales Mgr	Mgr · Sr.Sup(영업) · Eri	본사 영업	견적 · 수주 승인 · 마진 1차 승인 · 원가열람	4
R3	영업 담당자 / Sales Staff	TL · JS · Staff(영업)	담당 고객	견적 · 수주 생성 · 표준마진 ↑ 자유 / ↓ 상신	9
R4	수입 · 구매 관리자 / Imp · Pur Mgr	수입 · 구매 총괄 조세권 (KR)	전사 수입 · 구매	발주 · B/L · PIB · DO 총괄 · 원가 / Landed Cost	한국 1
R5	수입 · 구매 담당자 / Imp · Pur Staff	수입 · 구매 TL · Staff	전사 수입 · 구매	발주 · 입고 · 원가입력 · PIB · DO · SNI 실무	5
R8	지원 관리자 / Support Mgr	재무총괄 김용덕 · 총무총괄 송주영 (KR) · Anna · Komang	전사 재무 · 관리	여신 · 미수금 총괄 · 고객 / 단가 마스터	2 + 한국 2
R9	지원 담당자 / Support Staff	회계 · 관리 Staff / TL	담당 업무	인보이스 · 데이터 입력 · 여신 조회	10
R10	창고 관리자 / Warehouse Mgr	Manager (창고 KRW) Firman Taurus	전 창고	재고 실사 · 조정 · 출고 승인 · 입고 검수	1
R11	창고 담당자 / Warehouse Staff	창고 Staff · JS	소속 창고	입출고 · 피킹 · 출고 · 배송	4
R12	지점장 / Branch Head	Branch Head (SBY Sulastri · SMR Putra Purnama)	소속 지점	지점 전 모듈 · 지점 마진 · 여신 1차 승인	2
R13	지점 담당자 / Branch Staff	지점 영업 · 관리 · 창고 Staff	지점 · 담당	지점 범위 견적 · 수주 · 입출고 · 원가 비공개	10
NA	접속권한 없음 / No Access	Sopir 4 · Non Staff 10	—	ASM 미사용 — 계정 미부여, 물리 · 모바일 보안 대상	14
EA	비상 관리자 / Emergency	Break-glass 임시계정	전사 (한시)	장애 · 부재 시 24h 전권 (이중승인 · 자동 만료)	한시

3. 기능 권한 기준 Kriteria Hak Fungsi

기능	View	Create / Edit	Approve / Confirm	Export
Purchase PO	R1 / R4 / R5 / R8 / R10 등 업	R4 / R5	R4 또는 승인매트릭스	L4 R1 / R4 / R8 조건부

기능	View	Create / Edit	Approve / Confirm	Export
	무필요			
Quotation / SO	R1 / R2 / R3 / R8 / R12 / R13 (C1)	R2 / R3 / R12 / R13	R2 / R12 → R1 조건부	R2 / R12 범위 내
Inventory	수량 L2 광범위	R10 / R11	조정 R10 → R8	실무자 금지
Customer / AR	R2 / R3(C1) / R8 / R9 / R12 / R13(C1)	R8 / R9 및 승인된 영업	여신 R8 → R1	R8 / R1
Master	업무필요	오너 / 관리자	오너 → R1 / R8	오너 승인
Access / Audit	R0-A / R0-B / R1 분리	R0-A	R0-B	R0-B 로그 검토

3.1 데이터 기밀등급

등급	대표 데이터	대외 반출
L4 극비	매입원가 · Landed Cost · 공급사 단가 · 여신한도 · 급여 · 감사로그	대외 반출 금지
L3 기밀	판매 마진율 · 고객별 단가 · 미수 잔액 · 재고 평가액	R1 승인
L2 사내	재고 수량 · 출고·배송 이력 · 고객 연락처 · 발주 진행상태	부서장 승인
L1 공개	제품 규격·브랜드 · 지점 주소 · 회사 소개	자유

3.2 필드별 마스킹 매트릭스 (C2 구현 기준 — 개발 필수)

필드 (Field)	등급	소유 부서	전체 열람 허용 역할	마스킹(***) 대상 역할	조건 코드
매입원가 (Harga Pokok)	L4	수입 · 구매	R1 · R4 · R5	R2 · R3 · R9 · R10 · R11 · R12 · R13 — 금액 전체 ***	C2
Landed Cost (관세 · 물류 포함)	L4	수입 · 구매	R1 · R4	R5 이하 전 역할 — 구성내역 비노출	C2
공급사 단가 · 결제조건	L4	수입 · 구매	R1 · R4 · R5	그 외 전 역할 — 공급사명까지 마스킹	C2
판매 마진율 (Margin %)	L3	영업	R1 · R2 · R4 · R8 · R12(자점)	R3 · R13 — 율(%)만 숨김, 금액은 표시	C2 C1
여신한도 (Plafon Kredit)	L4	재무	R1 · R8 · R12(자점)	R3 · R13 — 한도액 ***, 초과 여부만 신호 표시	C2 C1
미수 잔액 (Piutang)	L3	재무	R1 · R8 · R9 · R12(자점)	R3 · R13 — 본인 담당 고객 건만 조회	C1
고객별 판매단가	L3	영업	R1 · R2 · R8 · R12(자점)	R3 · R13 — 본인 담당 고객 건만 조회	C1

필드 (Field)	등급	소유 부서	전체 열람 허용 역할	마스킹(***) 대상 역할	조건 코드
급여 · 인사 · 계약 정보	L4	총무	R1 · R8(총무총괄)	그 외 전 역할 — 메뉴 자체 미노출	권한 없음
재고 수량 (Stok)	L2	창고	전 역할 조회 가능	— (마스킹 없음)	—
감사로그 (Audit Log)	L4	전산 · 보안	R0-B · R1(조회)	R0-A 포함 그 외 전 역할 — 접근 차단	권한 없음

3.3 부서별 데이터 오너십

부서 = 보안 도메인. 데이터 오너는 열람 · 반출 · 기밀등급 지정을 최종 결정하며, 마스터 변경 승인 주체는 5장 승인 매트릭스에 따름. R0-A는 실행 전담 · 승인 권한 미보유.

부서	소유 데이터	최고 등급	데이터 오너	대리인	대외 반출
수입 · 구매	원가 · Landed Cost · 공급사 단가 · 발주 · B/L · PIB	L4	R4 조세권	R5 팀리더	금지
재무 · 회계	여신한도 · 미수 · 결제조건 · 전표 · 자금계획	L4	R8 김용덕	R8 Anna Siska	R1 승인
영업	견적 · 수주 · 고객별 단가 · 마진율 · 고객 마스터	L3	R2 Eri Suhendri	R2 Hery	R1 승인
창고 · 물류	재고 수량 · 실사 조정 · 입출고 · 배송 이력	L2	R10 Firman Taurus	R11 Aris Budiana	부서장 승인
총무 · 인사	인사 · 급여 · 근태 · 계약서 · 고정자산	L4	R8 송주영	R8 Komang	금지
전산 · 보안	계정 · 권한 · 감사로그 · 시스템 설정 · 백업	L4	R0-B 금기돈	R0-A 이정규	금지
지점 SBY · SMR	지점 견적 · 수주 · 재고 · 미수 · 수금	L3	R12 Sulastri / Putra Purnama	—	R1 승인
경영	전사 KPI · 손익 · 사업계획 · 단가 정책	L4	R1 김재헌	R1 서종환	금지

3.4 데이터 오너의 책임

구분	책임 내용	주기	산출물	미이행 시
① 열람 승인	타 부서의 자기 부서 데이터 조회 요청 심사 · 승인 (R0-A는 시스템 반영만)	요청 시	열람 승인 기록	권한 부여 보류
② 반출 승인	Excel · CSV 내보내기 및 대외 문서 제공 사유 첨부 승인. L4는 오너 + R1 최종	요청 시	반출 신청서 · Export 로그	반출 차단
③ 분기 재인증	자기 부서 데이터 접근 사용자 목록 검토, 불필요 권한 회수 요청 · 서명	분기 1회	재인증 확인서	권한 자동 만료

구분	책임 내용	주기	산출물	미이행 시
④ 등급 유지	신규 항목 추가 · 변경 시 기밀등급(L1~L4) 지정	상시	등급 지정 요청	기본값 L3 적용

4. 직무분리 (SoD) Pemisahan Tugas

동시 보유 금지 조합 6종, 위험도순(필수 → 높음 → 권장). 권한 부여 시 시스템에서 차단 (SEC-FR-003).

금지 조합	역할	내부통제 사유	위험도
R0-A ✗ R0-B	시스템관리 + 보안·감사	관리 행위자와 감사 통제자는 반드시 분리	필수
R4 ✗ R8	수입·구매 + 회계·재무	P2P 통제 — 발주·검수·지급을 동일인이 보유 금지	높음
R0-A ✗ R8	시스템관리 + 재무	계정·권한 통제자가 재무 데이터 보유 금지	높음
R3 ✗ R8	영업 + 여신	영업이 자기 고객 여신을 승인 금지	높음
R10 ✗ R8	재고조정 + 회계	재고 조정과 회계 기표 분리	높음
R4 ✗ R10	수입·구매 + 재고조정	입고 등록과 재고 조정 분리	권장

지점 보상통제 — R13 구조적 예외

지점(SBY · SMR)은 인원 규모상 R13이 영업 · 관리 · 창고를 겸직 — R3 ✗ R8 · R10 ✗ R8 금지 조합 구조적 발생. 직무 분리 불가 시 보상통제로 대체, 보상통제 없는 겸직 불허.

발생 위험	보상통제 (대체 통제)	주기	담당	증빙
지점 영업의 자기 고객 여신 승인	R13 여신 승인 권한 자체 미보유 — R12 지점장 1차 → R8 본사 최종 승인 강제	건별	R12 · R8	전자결재 이력
지점 재고조정과 회계 기표 겸직	지점 재고 조정 시 R12 승인 필수 + 본사 R10 창고관리자 사후 확인	건별	R12 · R10	재고조정 로그
지점장(R12) 자기 기안 자기 승인	R12 본인 기안 건 R12 승인 불가 — 본사 R2 / R8 자동 상신 (결재 라우팅 강제)	건별	시스템	결재 라우팅 설정
지점 현금 수금과 입금 확인 겸직	수금 담당과 입금 확인 담당 인원 분리 배치 (지점 최소 2인)	상시	R12	입금 대사표
겸직에 따른 전반적 통제 약화	지점 거래 · 재고 · 미수 본사 정기 점검 및 이상 항목 R1 보고	월 1회	R8	지점 점검 보고서
지점 인원 감소로 보상통제 붕괴	상주 인원 2명 이하 시 여신 · 재고조정 권한 본사 즉시 회수	발생 시	R0-A · R8	권한 회수 기록

감사 대응 — 보상통제는 SoD 위반의 허용이 아닌 대체. 증빙 미생성 · 미보관 시 SoD 결함 판정. 분기 재인증 시 R0-B가 증빙 존재 여부 확인.

5. 승인 매트릭스 및 Workflow Matriks Persetujuan

10항목 — 누가 무엇을 어떤 조건에서 승인하는가. 신규 공급사 등록 · 매입가 변경 · 창고 마스터 변경 3항목은 2026-09-01 확정 신설 (정합성 E-1 ~ E-3). 한비로 전자결재 라우팅에 동일 반영.

업무	트리거 (발동 조건)	1차 승인	최종 승인	SLA
할인 판매	견적·수주가 < 표준마진	R2 / R12(지점)	R1	당일
여신 초과	미수 잔액 > 여신한도	R8	R1	당일
신규 고객 등록	고객 마스터 신규·상태변경	R8 / R12(지점)	R1	1영업일
신규 공급사 등록	공급사 마스터 신규·상태변경	R4	R1	2영업일
판매가 변경	표준 판매단가·표준마진 변경	R2	R1	1영업일
매입가 변경	공급사 단가·표준 매입원가 변경 (L4 극비)	R4	R1	1영업일
재고 조정	실사 차이·폐기·등급변경	R10	R8	당일
창고 마스터 변경	창고 신설·폐쇄·TYPE(자가 / 3PL) 변경	R10	R8	1영업일
수입비용 확정	Landed Cost · 관세 확정	R4	R1	입항 前
권한 변경	역할 부여·회수	R0-B	R1	당일

5.1 전표 상태전이와 승인 이력

TO-BE 상태: DRAFT → SUBMITTED → APPROVED → CONFIRMED → CANCELLED / REVERSED. 반려 시 SUBMITTED → REJECTED → DRAFT. AS-IS는 DRAFT → CONFIRMED 2단계이며 결재선 팝업(PREPARED BY · CHECKER 1 · 2 · APPROVER 1)은 필수값 아님 → 금액 구간별 필수 결재선 · 결재 완료 건만 CONFIRMED 전환 · 결재 알림(이슈 34) 요구.

승인 이력 필수 항목	내용
식별	문서 ID · 문서 유형 · 승인 단계 (1차 / 최종)
주체 · 시각	승인자 (역할 · 사용자 ID) · 승인일시 · IP / 단말
결과	승인 결과 (APPROVED / REJECTED) · 의견 · 이전 상태 · 변경 상태
SLA	트리거 시각 대비 처리 시간, SLA 초과 여부 (당일 · 1영업일 · 2영업일 · 입항 前)

5.2 사용자 생애주기 (User Lifecycle)

이벤트	권한 조치	ASM 화면	담당	SLA

이벤트	권한 조치	ASM 화면	담당	SLA
입사 (Onboarding)	직책 기반 역할 자동 매핑 + 계정 생성	Search Staff	R0-A	입사일
부서 이동 (Transfer)	기존 역할 회수 + 신규 역할 부여 (SoD 재검증)	Search Staff	R0-A / R0-B 검토	발령일
승진 (Promotion)	상위 역할 부여 + SoD 충돌 재검증	Search Staff	R0-A	발령일
휴직 (Leave)	계정 일시 비활성화 (데이터 보존)	Search Staff	R0-A	휴직 시작일
퇴사 (Offboarding)	계정 즉시 비활성화 · 세션 종료 → 90일 후 삭제 · 데이터 이관	Search Staff	R0-A / R0-B	퇴사 당일
정기 재인증 (Recert)	전 사용자 역할 적정성 재인증	보고서	R0-B · R1	분기별
상시	본인 비밀번호 변경	Change Password	전 사용자	—

6. 감사로그 · 비상권한 Audit Log · Emergency Access

6.1 감사로그 (Audit Log)

구분	내용
기록 이벤트	로그인 · 로그아웃 · 권한 변경(부여·회수) · 고객정보 수정 · 원가 · Landed Cost 변경 · 재고 조정 · 가격 · 마진 변경 · 승인 이력 · 데이터 내보내기(Export)
기록 필드	사용자ID · 역할 · 액션 · 대상엔티티 · 변경 전/후 · 일시(ts) · IP / 단말
보관 기준	최소 3년 · 권장 5년. append-only / 해시체인 방식으로 위변조 방지
관리 · 조회	관리 R0-B (보안 관리자) · 조회 R1 (경영진). R0-A 시스템 관리자는 접근 차단

6.2 비상권한 (Break-glass)

구분	내용
발동 사유	관리자 부재 · 퇴사 / 비밀번호 분실 / 시스템 장애
역할 · 발급	Emergency Admin(EA) 임시 전권. R1 + R0-B 이중 승인으로 발급
제어	24시간 자동 만료 · 전 행위 자동 로깅 · 사용 후 즉시 회수
사후 검토	익영업일 R0-B · R1 공동 검토

7. 데이터 반출 · 물리 · 모바일 보안 Kontrol Ekspor · Keamanan Fisik

7.1 데이터 반출(Export) 통제 — 권한 매트릭스 Export 열 연동

반출 유형	허용 역할	조건	비고
Excel · CSV (L4 포함)	R1 · R4 · R8	데이터 오너 승인 + 반출 사유 입력 필수	워터마크(사용자ID·일시) 자동 삽입
Excel · CSV (L3 이하)	R1 · R2 · R4 · R8 · R12	반출 사유 입력 · 자기 범위(C1) 내로 제한	1회 5,000행 초과 시 승인 전환
Excel · CSV	R3 · R5 · R9 · R10 · R11 · R13	금지 — 화면 조회만 가능	필요 시 R2 / R12가 대행 반출
PDF · 인쇄 (견적서·인보이스·DO)	R2 · R3 · R8 · R9 · R12 · R13	업무 문서에 한함	원가·마진 필드 미포함 양식 사용
보고서 대외 제공 (고객·감사인·은행)	R1	데이터 오너 승인 → R1 최종 승인	제공처·목적 기록 보관
API 대량 조회 · DB 직접 접근	R0-A	사전 신청 · 건수 제한 · R0-B 사전 통보	1회 5,000건 초과 시 자동 차단
화면 캡처 · 사진 촬영 (L3 이상)	전 역할 금지	—	적발 시 위반 조치 기준 적용

Export 열 판독 — ● 전 등급(L4 포함) 반출 가능 · ◐ L3 이하 자기 범위(C1) 내 · ◍ 사전 신청 · 건수 제한 · ○ 반출 실행 불가(Export 로그 조회 전용, R0-B) · — 반출 불가. 월 1회 R0-B가 Export 로그 검토(비업무시간 · 대량 · 반복 · 퇴사 예정자 반출) → R1 보고, 3년 보관.

7.2 물리 · 모바일 보안 — NA 14명 포함 전 임직원

대상	위험	통제 조치	담당 · 주기
Sopir 4명 (계정 미부여)	차량 내 배송서류 방치, 고객정보 노출	배송 서류 당일 반납 · 잔여 서류 파쇄 · 차량 내 보관 금지	R10 · 월 1회
Non Staff 10명 (창고)	재고·출고 화면 어깨너머 열람, 휴대폰 촬영	창고 단말 화면 잠금 5분 · 작업구역 촬영 금지 · 반입 통제	R10 · 월 1회
창고 공유단말 (WMS)	계정 공유로 행위자 추적 불가	개인 계정 필수 · 공유계정 생성 금지 · 자동 로그아웃 10분	R0-A · 분기
WhatsApp · 개인 메신저	재고표·단가표·견적서 사진 전송	L3 이상 화면의 촬영·전송 금지 · ASM 링크로만 공유	R8 · 상시
개인 노트북 · USB	무단 데이터 반출	회사 지급 단말만 접속 허용 · USB 쓰기 차단	R0-A · 분기
원격 · 외부 접속	계정 탈취 · 부정 접속	2단계 인증(MFA) 필수 · 해외 IP 차단 (출장 시 한시 허용)	R0-B · 상시

대상	위험	통제 조치	담당 · 주기
퇴사자 · 부서 이동자	계정과 물리 출입 권한 잔존	퇴사 당일 계정 비활성 + 출입카드·단말·서류 회수 동시 처리	R0-A · R8
외부 방문자 · 협력사	사무실 · 창고 내 정보 노출	방문자 대장 기록 · 동행 필수 · 업무구역 촬영 금지	R8 · 상시

7.3 보안 서약 · 교육 · 위반 조치

구분	대상	내용	주기	담당
보안 서약서 (Pakta Integritas)	전 임직원 68명 (NA 14명 포함)	정보 반출 · 촬영 금지 · 퇴사 후 비밀유지 서명	입사 시 · 연 1회	R8 (총무)
개인정보 취급 교육	R2 · R3 · R8 · R9 · R12 · R13	UU No. 27/2022 (PDP) 고객정보 수집 · 이용 · 보관 기준	연 1회	R8 (총무)
권한 · 보안 교육	R0-A · R0-B · R1 · R2 · R4 · R10 · R12	승인 책임 · SoD · 보상통제 증빙 작성	연 1회	R0-B
위반 조치 기준	전 임직원	1차 서면 경고 → 2차 권한 회수 · 재교육 → 3차 인사위원회	발생 시	R8 · R1
보안 사고 신고	전 임직원	계정 유출 · 분실 · 오전송 인지 즉시 R0-B 신고 (자진 신고 시 감경)	발생 시	R0-B

8. 근거 자료 및 확인 범위 Dasar Referensi

- ASM 권한 가이드라인 v3.0 변경본 (2026.08)
- ASM 업무 프로세스 맵 HWPX 변경본 (기준일 2026-09-01, 38건 동기화)
- ASM 업무 프로세스 정의서 HWPX 변경본 (기준일 2026-09-01, 38건 동기화)
- ASM 시스템 테스트 결과 및 개선 의견서 HWPX 변경본 (총 38건)
- ASM 문서 정합성 검증 리포트 v3.3
- ASM 디자인 가이드(안) — AsuraDB 디자인 시스템 적용 기준
- ERP 웹앱 개발 순서 및 필요 문서
- ASM 실화면 확인: https://asm.ascendotyre.com/ (2026-09-02)

테스트 이슈 공식 기준선: 사용자 확인에 따라 총 38건(S1 2 · S2 18 · S3 18)으로 확정. 업무 프로세스 구본의 27건 표기는 이전 집계로 간주. 변경본의 현지 사용자 요청 이슈 28~38 및 정합성 검증 리포트 시정사항 반영.

2026-09-03

PT ASCENDO INTERNASIONAL

붙임 1. 역할 × 모듈 권한 매트릭스 (16 모듈) Lampiran 1. Matriks Peran × Modul

● 전체 ◐ 편집 ○ 조회 ◍ 조건부(C1~C4) — 없음 | EA = 24h 한시 | ★ 내보내기(Export) 열 — Excel · CSV · API 반출을 권한 축으로 분리. 출처: ASM 권한 가이드라인 v3.0 (2026.08) 03 권한 매트릭스.

역할 ₩ 모듈	Dash	Cust	Quote	Order	Margin	Stock	Ship	AR	Purch	Impor	Report	Export ★	Master	Access	Approve	Audit
R0-A 시스템 관리자	●	○	○	○	○	○	○	○	○	○	●	◍	◐	●	◐	○
R0-B 보안 관리자	◐	○	—	—	—	—	—	—	—	—	○	○	—	◍	○	●
R1 경영진	●	●	○	●	●	○	○	●	○	○	●	●	◐	○	●	○
R2 영업 관리자	◐	◐	●	●	◐	○	◍	○	—	—	◐	◐	◍	—	◐	◍
R3 영업 담당자	◍	◍	◐	◐	◍	○	○	◍	—	—	◍	—	◍	—	—	—
R4 수입 · 구매 관리자	◐	—	—	○	◐	○	◍	○	●	●	◐	●	◐	—	◐	◍
R5 수입 · 구매 담당자	◍	—	—	○	◍	○	◍	—	◐	◐	◍	—	◍	—	—	—
R8 지원 관리자	◐	●	○	○	○	○	○	●	○	○	◐	●	◐	—	◐	◍
R9 지원 담당자	◍	◍	◍	◍	○	◍	—	◐	◍	—	◍	—	◍	—	—	—
R10 창고 관리자	◐	—	—	○	—	●	●	—	◐	◍	◐	—	◍	—	◐	◍
R11 창고 담당자	◍	—	—	○	—	◐	◐	—	◍	◍	—	—	—	—	—	—
R12 지점장	◐	◐	●	●	◍	◐	◐	◐	◍	—	●	◐	◍	—	◐	◍
R13 지점 담당자	◍	◍	◐	◐	◍	◍	◍	◍	—	—	◍	—	◍	—	—	—

역할 ₩ 모듈	Dash	Cust	Quote	Order	Margin	Stock	Ship	AR	Purch	Impor	Report	Export ★	Master	Access	Approve	Audit
NA 접속권한 없음	—	—	—	—	—	—	—	—	—	—	—	—	—	—	—	—
EA 비상 관리자	●	●	●	●	●	●	●	●	●	●	●	●	●	●	●	●

Dash 대시보드 · Cust 고객/CRM · Quote 견적 · Order 수주/판매 · Margin 가격/마진 · Stock 재고 · Ship 출고/배송 · AR 청구/미수 · Purch 구매/입고 · Impor 수입/통관 · Report 보고서 · Export 내보내기 · Master 마스터 · Access 사용자/권한 · Approve 전자결재 · Audit 감사로그